Johnson Controls Firmware Attack Surface & Detection Brief

Johnson Controls Firmware Attack Surface & Detection Brief

Scope: CVE and public-advisory research only — firmware has not yet been acquired or extracted (JCI's Building Technologies partner portal requires a login this project does not have). No direct binary examination; findings below are from public vulnerability disclosures (CISA ICS advisories, NVD), Johnson Controls' own product security advisories (PSA), and public product documentation. There are no extracted hashes, no rootfs service enumeration, and no carved files for this vendor — unlike the Eaton brief, nothing below describes an actual binary.

Why now: A fresh cross-reference against the ARNG's full nationwide OT device census (5,723 OT & Building Systems devices, ForeScout + Dragos exports) found **Johnson Controls, Inc.** (OUI-derived vendor string) is the **5th-largest OT vendor by device count — 302 devices** — with zero coverage across the 14 firmware briefs already in this folder. Those 14 skew toward industrial-process-control vendors (Rockwell, SEL, Siemens) that are a small fraction of this specific inventory; the actual population is dominated by building-automation/physical-security vendors. This brief closes that gap for Johnson Controls' Metasys building management system (BMS), one of six device-count-driven vendor briefs being produced in parallel (Tridium, Mercury Security, Bosch Security, Axis Communications, Aiphone are the others).

Purdue layer mapping: Metasys is a 3-tier BMS architecture and the three tiers land on three different Purdue layers, not one. **FEC/IOM field controllers** do direct I/O against sensors/actuators over BACnet MS/TP or the legacy N2 bus — this is the same basic-control role the purdue-l1-basic-controllers-brief.md Group D (RTU/remote outstation) describes, so FEC/IOM sits at **Purdue L1 (Basic Control)**, extending Group D with a BACnet-native field-controller class. **NAE/NIE and SNE/SNC network/supervisory engines** aggregate multiple field controllers, run area-level scheduling/trending/alarm logic, and serve a local operator web UI (Site Management Portal) — functionally the area-supervisory role described in purdue-l2-area-supervisory-brief.md, even though that brief's existing material is HMI-panel-centric (it says so explicitly in its own scope line); NAE/NIE/SNE/SNC extend L2 with a supervisory-controller class rather than an HMI-runtime class. **Metasys Server (ADS/ADX/OAS)** is the site-wide server — historian, full System Management Portal, scheduling, alarm management across every NAE/NIE/SNE on site — which is the same role purdue-l3-site-operations-brief.md Group A (SCADA/HMI Server) assigns to WinCC, FactoryTalk View SE, Citect, and Experion PKS Server. ADS/ADX is JCI's SCADA-server equivalent for buildings.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A. NAE/NIE Network Engines	L2 Area Supervisory (extends)	Network Automation Engine (NAE55xx), Network Integration Engine (NIE55/59), legacy NCE25	Embedded Linux/VxWorks, BACnet/IP (UDP/47808) + BACnet MS/TP + legacy N2 bus, Site Management Portal (HTTP/HTTPS) web UI	research only — not yet acquired
B. Metasys Server (ADS/ADX/OAS)	L3 Site Operations	Application and Data Server (ADS), Extended ADS (ADX), Open Application Server (OAS), LCS8500/NAE8500, System Configuration Tool (SCT), Controller Configuration Tool (CCT)	Windows Server + SQL Server/SQL Server Express, IIS, System Management Portal / MUI web client	research only — not yet acquired
C. SNE/SNC Supervisory Engines	L2 Area Supervisory (extends)	Space/Supervisory Network Engine (SNE), Supervisory Network Controller (SNC); adjacent commercial line: Facility Explorer F4-SNC	Embedded Linux, BACnet/IP, local web UI, smaller-footprint equivalent of NAE	research only — not yet acquired
D. FEC/IOM Field Controllers	L1 Basic Control	Field Equipment Controller (FEC) family, Field Application Controller (FAC), Input/Output Module (IOM), CGM/CVC/PCA/PCV/VMA field controllers	Bare-metal MCU, BACnet MS/TP + legacy N2 field bus, no IP stack on most SKUs	research only — no confirmed CVE found specific to this product line (see Group D below)

Group A — NAE/NIE Network Engines — Purdue L2 Area Supervisory (extends)

NAE/NIE engines sit on the management/BAS VLAN, speak BACnet/IP upstream to ADS/ADX and BACnet MS/TP or N2 downstream to field controllers, and serve a local Site Management Portal web UI used for direct engineering access when the central server is unavailable — a common misconfiguration point since that local web UI is often left enabled by default on the BAS VLAN.

Confirmed CVEs:

CVE	Product	Vector	Notes
CVE-2014-5427	Metasys 4.1–6.5: ADS, ADX, LonWorks Control Server LCS8520, **NAE** 5510-2/5510-2U/5511-2/5520-2/5521-2, **NIE** 5510-2/5511-2, NxE8500	Unauthenticated remote attacker reads password hashes via a crafted POST request (CWE-200)	No vendor-published fix listed in the public record; treat any unpatched legacy NAE/NIE on this range as compromised-by-default for credential material
CVE-2019-7593	Metasys <9.0: ADS/ADX servers + NAE/NIE/NCE engines	Nonce/RSA key pair reuse (CWE-323) across devices; attacker who captures the shared key pair can decrypt Site Management Portal traffic	CVSS v3 6.8; fix: upgrade to 9.0+ and configure trusted certs

CVE	Product	Vector	Notes
(ICSA-19-227-01)			
CVE-2019-7594 (ICSA-19-227-01)	Same as above	Hardcoded RC2 key (CWE-321) used for SMP encryption, same decrypt-captured-traffic impact	CVSS v3 6.8; same fix
CVE-2021-27657 (ICSA-21-159-01)	Metasys servers, engines (incl. NAE), and tools, versions prior to 9.0/10.0/10.1/11.0	Improper privilege management (CWE-269) — authenticated user sends crafted web messages to gain unintended server-filesystem access/modification	CVSS v3 8.8 — highest-severity confirmed hit directly naming "engines"

Top attack vector (MITRE ATT&CK ICS): T0859 Valid Accounts via the decrypted/disclosed credential material (CVE-2014-5427, CVE-2019-7593/7594), chained into T0836 Modify Parameter via BACnet `WriteProperty` against the field controllers the NAE/NIE supervises. The shared-key design flaw (CVE-2019-7593/94) is structurally the same class as default/shared-credential weaknesses that recur across BAS vendors.

Group B — Metasys Server (ADS/ADX/OAS) — Purdue L3 Site Operations

This is where the confirmed CVE volume concentrates — ADS/ADX/OAS is the site-wide web server and database, and most JCI PSAs/CISA advisories target it directly.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Notes
CVE-2021-36200 (ICSA-22-202-02)	5.3	ADS/ADX/OAS with MUI, v10, v11	Missing authentication for critical function (CWE-306) — unauthenticated web API user enumeration	Fixed: 10.1.6 / 11.0.2
CVE-2021-36204 (ICSA-23-012-06)	7.8	ADS/ADX/OAS, v10, v11	Insufficiently protected credentials (CWE-522) — plaintext credentials exposed via API calls to unauthenticated users	Fixed: 10.1.6 / 11.0.3
CVE-2021-36205 (ICSA-22-104-02)	8.1	ADS/ADX/OAS, v10, v11	Incomplete cleanup (CWE-459) — session token not cleared on logout, reusable by a remote attacker	Fixed: 10.1.5 / 11.0.2
CVE-2022-21934 (ICSA-22-125-01)	8.0	ADS/ADX/OAS, v10, v11	Unverified password change (CWE-620) — authenticated user can lock out other users and take over accounts	Fixed: 10.1.5 / 11.0.2

CVE	CVSS	Product	Vector	Notes
CVE-2025-26385 (JCI-PSA-2026-02)	9.5 (CVSS 4.0; some trackers report up to 10.0)	ADS, ADX, LCS8500/NAE8500, SCT 17.1 and prior, CCT 17.0 and prior — all when deployed with SQL Server Express	Command injection (CWE-77) → remote, unauthenticated arbitrary SQL execution	Metasys 14.1 and prior affected; mitigation includes blocking inbound TCP/1433 and patching SQL Express itself, not just the Metasys app layer
CVE-2026-34491 (ICSA-26-225-14 / JCI-PSA-2026-11)	8.7 (v3) / 8.6 (v4)	Metasys 12.x, 13.x (both EOL — no fix available), 14.x <14.1.5, 15.x <15.0.1	Persistent cross-site scripting (CWE-79) — low-privilege user injects a script via crafted URL that executes in other users' (incl. admin) sessions on later login	Fixed in 16.0 and in 14.1.5/15.0.1; **12.x and 13.x are end-of-support and will not receive a patch**

Top attack vector (MITRE ATT&CK ICS): T0859 Valid Accounts is the common thread across five of the six confirmed ADS/ADX CVEs — unauthenticated user enumeration (CVE-2021-36200), credential disclosure (CVE-2021-36204), session-token reuse (CVE-2021-36205), account takeover via unverified password change (CVE-2022-21934), and session hijack via stored XSS (CVE-2026-34491) all converge on "become, or impersonate, an authenticated Metasys user." The 2025 command-injection class (CVE-2025-26385) is the outlier — straight T0807 Command-Line Interface-style remote code execution with no auth required at all.

Group C — SNE/SNC Supervisory Engines — Purdue L2 Area Supervisory (extends)

SNE/SNC are the smaller-footprint supervisory engine line (no field controllers wired directly in some deployments) and share firmware/web-stack lineage with NAE. The adjacent Facility Explorer line (JCI's lighter commercial BAS product, F4-SNC model) was named in the same advisory as Metasys SNE/SNC, confirming shared code.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Notes
CVE-2023-4486 (ICSA-23-341-03)	7.5	Metasys **NAE55**, **SNE**, **SNC** engines; Facility Explorer **F4-SNC**, all versions prior to 11.0.6 / 12.0.4	Uncontrolled resource consumption (CWE-400) — sending invalid auth credentials to the login endpoint makes the engine unresponsive	Pure pre-auth DoS against the login endpoint itself — no credentials needed to take an engine offline

Top attack vector (MITRE ATT&CK ICS): T0814 Denial of Service — an unauthenticated attacker on the BAS VLAN can knock a supervisory engine offline simply by hammering its login endpoint with bad credentials, no exploit chain required.

Group D — FEC/IOM Field Controllers — Purdue L1 Basic Control

No public CVE specifically naming FEC, FAC, IOM, or the CGM/CVC/PCA/PCV/VMA field-controller lines was found as of this research (searched CISA ICS advisories, NVD, and JCI's own PSA index for "Johnson Controls" + "FEC" / "IOM" / "field controller"). This is consistent with the pattern seen on the Eaton brief's legacy-NMC family: EOL/low-scrutiny device classes with no public CVE history are not evidence of no bugs, only evidence that nobody has looked. Two adjacent, non-FEC/IOM data points are worth noting instead of inventing a direct hit:

- CVE-2018-10624 (ICSA-18-212-02, CVSS 4.3) covers "Metasys System" ≤8.0 broadly plus the separate BCPro (BACnet router/gateway) product — information exposure via HTTP error messages (CWE-209). BCPro is a BACnet router/gateway, not a field controller, but it is architecturally adjacent (same field-bus trust boundary) and from the same era.
- Field controllers of this class run BACnet MS/TP (RS-485, no native authentication in the protocol itself) and/or the legacy N2 bus (also unauthenticated). Any attacker with physical or pivoted access to the field bus has full read/write over every point on that trunk — this is a protocol-level property, not a Johnson-Controls-specific bug, and it recurs across every BACnet-native vendor in this project (see the Eaton brief's BACnet/UDP-47808 note on the M2 NMC).

Top attack vector (MITRE ATT&CK ICS): T0836 Modify Parameter via BACnet `WriteProperty` or N2 point write from anything that reaches the field bus — no authentication bypass is even required, because the protocol has none.

Logging / detection matrix (ordered by detection value)

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	**Metasys ADS/ADX audit log (Site Management Portal → Audit Trail)**	`User logon failed` × N then `success`; `Password changed` for an account not initiating its own change	Brute force success; CVE-2022-21934-style account takeover	T0812 Default Credentials + T0859 Valid Accounts
2	ADS/ADX audit log	`Configuration changed` / schedule or setpoint edit outside a change-ticket window	Unauthorized parameter tamper via a captured session	T0836 Modify Parameter
3	**Network IDS (Suricata/Zeek)**	BACnet/IP (UDP/47808) `WriteProperty` or `Who-Is` / `I-Am` floods crossing the corporate→BAS VLAN boundary	Direct point tamper or reconnaissance against NAE/NIE/SNE/SNC and FEC/IOM	T0836 Modify Parameter
4	Network IDS	Repeated failed-auth bursts at an NAE/NIE/SNE/SNC login endpoint (HTTP)	CVE-2023-4486-class pre-auth DoS attempt against the login endpoint	T0814 Denial of Service
5	Network IDS	Inbound TCP/1433 (SQL Server) reaching an ADS/ADX host from outside the local admin subnet, or reachable from the internet at all	CVE-2025-26385 exploitation path (SQL Express exposed)	T0883 Internet Accessible Device
6	**Windows Security Event Log on ADS/ADX host**	EventID 4624/4625 (logon) for the Metasys service account outside its expected process	Lateral movement using a Metasys service account;	T0859 Valid Accounts

#	Source	Event	What it catches	MITRE ATT&CK ICS
		tree; EventID 4720 (account created) on the Metasys-hosting Windows Server	new local account created post-compromise	
7	**Sysmon on ADS/ADX host**	EventID 1 ProcessCreate where ParentImage = SQL Server/SQL Express process AND child = `cmd.exe` / `powershell.exe`	CVE-2025-26385 post-exploitation (command injection → OS command execution via SQL)	T0807 Command-Line Interface
8	**Browser/session telemetry on operator workstations opening the Site/System Management Portal**	Unexpected outbound requests or DOM mutations immediately after a Metasys login	CVE-2026-34491 stored-XSS → session-hijack execution	T0859 Valid Accounts

Secondary:

- Firewall/segmentation: BAS VLANs hosting NAE/NIE/SNE/SNC/FEC/IOM should never originate outbound traffic to the internet, and corporate IT should not be able to reach BACnet/IP (UDP/47808) or the ADS/ADX SQL backend (TCP/1433) directly — CVE-2025-26385's own mitigation explicitly calls out closing TCP/1433 from untrusted networks.
- Johnson Controls does not document a standardized syslog/SNMP-trap export comparable to Eaton's NMC or Vertiv's ACS 8000 in public material reviewed for this brief — the Site/System Management Portal's internal **Audit Trail** is the closest first-party log source and should be forwarded to SIEM via whatever ODBC/SQL-level export the deployment supports; this is a detection gap relative to other vendor families in this project and should be validated once firmware/documentation access is obtained.
- BACnet traffic baselining (Zeek's `bacnet` analyzer or equivalent): alert on any `WriteProperty` to a priority array slot other than the one the site's sequence-of-operations expects — priority-array abuse is the BACnet-native equivalent of a Modbus coil-write attack and is not covered by any of the CVEs above because it is a protocol-trust issue, not a software bug.

Specific concerns for this dataset

1. **302 devices makes Johnson Controls the 5th-largest OT vendor in this census, with zero firmware-brief coverage before this document.** At that scale, even a conservative read of the confirmed CVE list above (12 CVEs across 8 CISA ICS advisories plus 2 JCI-only PSAs from 2014 through 2026) implies a meaningful fraction of those 302 devices are running ADS/ADX or NAE/NIE/SNE/SNC builds predating the 2021–2022 patch wave (CVE-2021-36200/36204/36205, CVE-2022-21934) — those four alone cover a two-year span of the exact "authenticate as someone else" attack class that chains directly into BACnet point writes.

2. **Metasys 12.x and 13.x are end-of-support and will not receive a fix for CVE-2026-34491 (stored XSS → session hijack, CVSS 8.6–8.7).** Any device census host still resolving to a pre-14.1.5/15.0.1 Metasys build is running an unpatchable vulnerability by vendor policy, not just an unpatched one — this is a forced-upgrade-or-accept-risk decision for whatever fraction of the 302 devices falls in that

version range, and the census as described (OUI-derived vendor only, no model/firmware version) cannot currently distinguish which devices those are.

3. **CVE-2025-26385 (command injection → unauthenticated remote SQL execution, CVSS 9.5–10.0) is the single highest-severity confirmed finding in this brief**, and it specifically targets the ADS/ADX/LCS8500/NAE8500 + SQL Express combination — a very common small-to-midsize-site deployment pattern. If any ARNG facility's Metasys Server was stood up with the default SQL Express install and TCP/1433 reachable from a shared management network, this is a pre-auth path to the server that holds every site's schedules, setpoints, and historian data.

4. **No confirmed CVE exists against FEC/IOM field controllers specifically.** Given BACnet MS/TP and N2 have no native authentication, the field-bus layer's actual risk is structural (anyone who reaches the bus has full point access) rather than CVE-driven — meaning network segmentation of the BAS field-bus trunks matters more than patch status for this specific product class, and no patch will ever close it.

5. **JCI's September 2023 corporate ransomware incident (reported Dark Angels group, ~27 TB claimed stolen, >$27M in company-reported remediation cost) was explicitly stated by Johnson Controls in SEC filings to be confined to internal IT infrastructure, with "no evidence of any impact" to Metasys or OpenBlue.** This brief does not treat that incident as an OT compromise — it is cited here only as corporate-risk context (a company this large being a ransomware target says something about its overall security posture and supply-chain risk to customers who depend on its patch pipeline, portal access, and advisory cadence), not as a Metasys-specific finding. Do not cite it elsewhere in this project as a BMS/OT breach — the public record does not support that.

6. **The firmware-access gap is itself a finding.** This project could acquire and directly examine Eaton, and presumably other vendors', firmware without a paid/gated account; Johnson Controls' Building Technologies partner portal requires a login this project does not have. That gating is consistent with JCI's own product-security posture (responsible-disclosure PGP contact, structured PSA numbering) but means ARNG cannot independently verify firmware integrity on any deployed Metasys device without either a JCI partner relationship or physical extraction — a meaningfully higher operational barrier than vendors whose firmware is openly downloadable.

Sources

- CISA ICSA-18-212-02 — Johnson Controls Metasys and BCPro (CVE-2018-10624)
- CISA ICSA-19-227-01 — Johnson Controls Metasys (CVE-2019-7593, CVE-2019-7594)
- CISA ICSA-21-159-01 — Johnson Controls Metasys (CVE-2021-27657)
- CISA ICSA-22-104-02 — Johnson Controls Metasys (CVE-2021-36205)
- CISA ICSA-22-125-01 — Johnson Controls Metasys (CVE-2022-21934)
- CISA ICSA-22-202-02 — Johnson Controls Metasys (CVE-2021-36200)
- CISA ICSA-23-012-06 — Johnson Controls Metasys (CVE-2021-36204)
- CISA ICSA-23-341-03 — Johnson Controls Metasys and Facility Explorer (CVE-2023-4486)
- CISA ICSA-26-225-14 — Johnson Controls Metasys (CVE-2026-34491)
- INCIBE-CERT — CVE-2014-5427 (Metasys password hash disclosure)
- CVEfeed — CVE-2025-26385 (Metasys SQL Express command injection)

- Johnson Controls — Trust Center Product Security Advisories (JCI-PSA index)
- Johnson Controls — cyber-solutions security advisories (legacy index)
- Tenable OT plugin 505941 — CVE-2026-34491 detail
- BleepingComputer — Johnson Controls ransomware attack cost $27 million, data stolen
- SecurityWeek — Johnson Controls ransomware attacks, data theft confirmed, cost exceeds $27 million
- Johnson Controls — SEC Form 10-Q FY2024 (incident scope: internal IT infrastructure only, no evidence of impact to Metasys/OpenBlue)
- MITRE ATT&CK for ICS — T0812 Default Credentials
- MITRE ATT&CK for ICS — T0814 Denial of Service
- MITRE ATT&CK for ICS — T0836 Modify Parameter
- MITRE ATT&CK for ICS — T0859 Valid Accounts
- MITRE ATT&CK for ICS — T0807 Command-Line Interface
- MITRE ATT&CK for ICS — T0883 Internet Accessible Device
- Internal: eaton-firmware-threat-brief.md (shape template), purdue-l1-basic-controllers-brief.md, purdue-l2-area-supervisory-brief.md, purdue-l3-site-operations-brief.md

---

php2shell (CVE-2026-109618 / CVE-2026-109619) determination - 2026-10-22

php2shell context: this brief's PHP determination was driven by CVE-2026-109618 / CVE-2026-109619 ("php2shell", CVSS 9.2, PHP 5.4+, emergency-patched 2026-10-21). Those two IDs are carried here **as supplied by the requester** - they were not independently corroborated against NVD/MITRE in this pass, and no vendor-specific CVE was invented to pair with them.

Gating verified. `johnsoncontrols.com/building-automation-and-controls/building-management/network-engines` returns **HTTP 404** (258,978 bytes of error/navigation content), and `docs.johnsoncontrols.com/bas/` returns HTTP 200 but is documentation, not a firmware store. Metasys firmware for NAE/NIE, Server ADS/ADX, SNE/SNC and FEC/IOM is distributed through the JCI dealer/partner channel. **Access verdict: NOT PUBLICLY DOWNLOADABLE at the paths tested.** No registration or credential attempt was made.

PHP finding: UNDETERMINED. No firmware acquired, so no filename, byte count or SHA256 to report. Metasys NAE/NIE historically ran a Windows-CE-derived or embedded-Linux stack with a Java-applet and later HTML5 UI; neither rules PHP in nor out without a rootfs. **302 devices remain unclassified for php2shell.**

Fastest route to a definitive answer: a live-device HTTP check against one of the 302 units - `X-Powered-By` header and `.php` handling - which needs no dealer access.